POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	FACULTAD DE INGENIERIAS DIPLOMADO EN CIBERSEGURIDAD LABORATORIO KALI LINUX	Código: FD-GC195 Versión: 01

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

FECHA		SEMESTRE	2026_02	
NOMBRE DEL ESTUDIANTE				
DOCUMENTO		GRUPO	02	
DOCENTE	EDWIN OCHOA	ASIGNATURA	DIPLOMADO CIBERSEGURIDAD	

Objetivo general de la práctica

Fortalecer las competencias técnicas y analíticas de los estudiantes del Diplomado en Ciberseguridad mediante la ejecución documentada de dos laboratorios controlados en Kali Linux, aplicando comandos de reconocimiento, enumeración, análisis de servicios, revisión de metadatos, acceso controlado a máquinas vulnerables y análisis de disponibilidad en WordPress, con el fin de comprender cómo se identifican vulnerabilidades, cómo se interpretan los resultados de la terminal y qué medidas defensivas pueden implementarse para reducir riesgos en entornos reales. La práctica debe desarrollarse únicamente en ambientes autorizados y de laboratorio.

Objetivo general de la práctica

Fortalecer las competencias técnicas y analíticas de los estudiantes del Diplomado en Ciberseguridad mediante la ejecución documentada de dos laboratorios controlados en Kali Linux, aplicando comandos de reconocimiento, enumeración, análisis de servicios, revisión de metadatos, acceso controlado a máquinas vulnerables y análisis de disponibilidad en WordPress, con el fin de comprender cómo se identifican vulnerabilidades, cómo se interpretan los resultados de la terminal y qué medidas defensivas pueden implementarse para reducir riesgos en entornos reales. La práctica debe desarrollarse únicamente en ambientes autorizados y de laboratorio.

Objetivos específicos

1. Ejecutar comandos básicos e intermedios en Kali Linux, tomando pantallazos de cada paso y explicando qué hace el comando, qué resultado entrega y qué decisión técnica permite tomar.
2. Aplicar técnicas de reconocimiento y enumeración sobre una máquina vulnerable, identificando servicios activos, puertos abiertos, posibles rutas de acceso y configuraciones inseguras.
3. Analizar archivos y metadatos para comprender cómo la información oculta en recursos digitales puede revelar datos sensibles que facilitan un ataque.
4. Comprender el funcionamiento de una vulnerabilidad asociada a WordPress y wp-cron.php, analizando cómo una mala exposición del servicio puede afectar la disponibilidad de una aplicación web.

5. Relacionar cada acción ofensiva del laboratorio con una medida defensiva, como control de acceso, limitación de peticiones, monitoreo, endurecimiento del servidor, configuración segura y buenas prácticas de administración.
6. Elaborar un informe técnico con evidencias, capturas de pantalla, explicación de comandos, análisis de resultados, conclusiones y recomendaciones de mitigación, demostrando comprensión ética y responsable del uso de herramientas de ciberseguridad.

PRÁCTICA INTEGRADORA DE KALI LINUX

Diplomado en Ciberseguridad Informática y Resiliencia Digital

Laboratorios: BorazuwarahCTF y prueba controlada de disponibilidad en WordPress con wp-cron.php

Documento complementado para orientar evidencias, pantallazos, explicación de comandos, análisis técnico y reflexión defensiva.

Uso exclusivo en entornos controlados, máquinas de laboratorio y prácticas autorizadas por el docente.

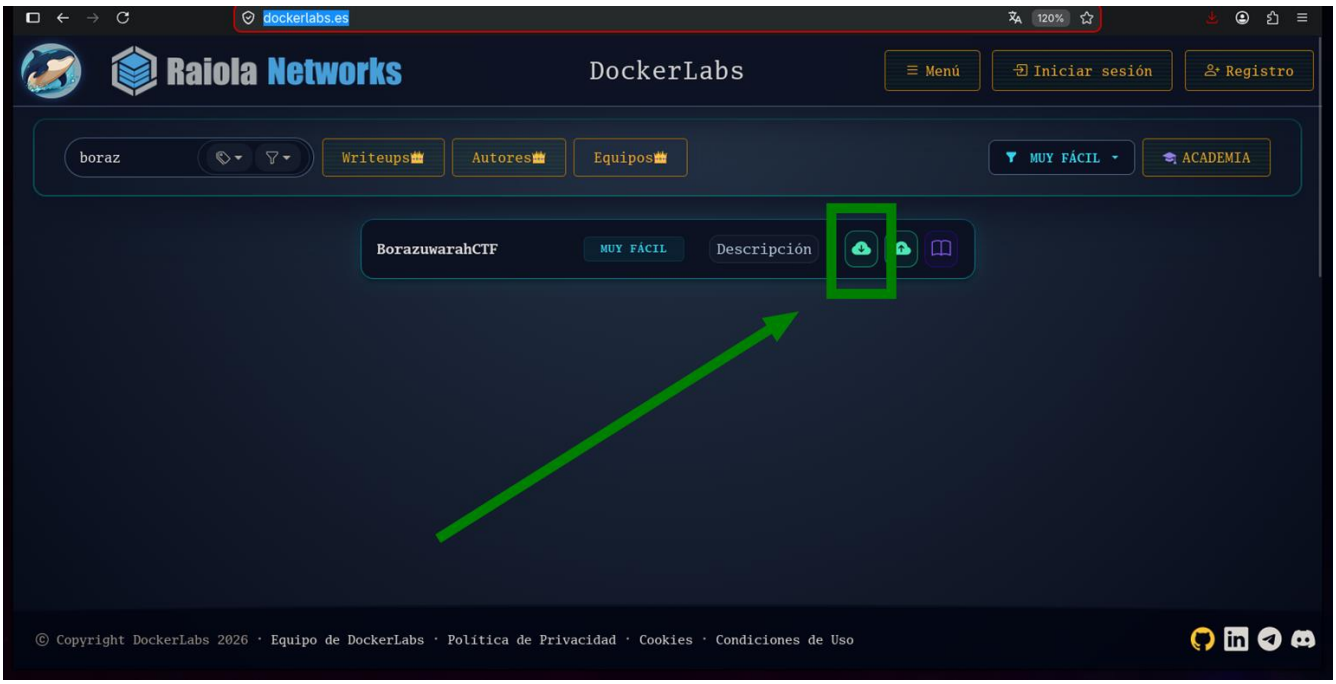
Propósito de la práctica: desarrollar competencias de reconocimiento, enumeración, análisis de resultados, uso responsable de herramientas de Kali Linux y propuesta de medidas de mitigación frente a vulnerabilidades observadas en laboratorio.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX			
PROFESOR: Edwin Andrés Ochoa Agudelo				FECHA: 06/10/2026	
TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

¿Qué es BorazuwarahCTF?

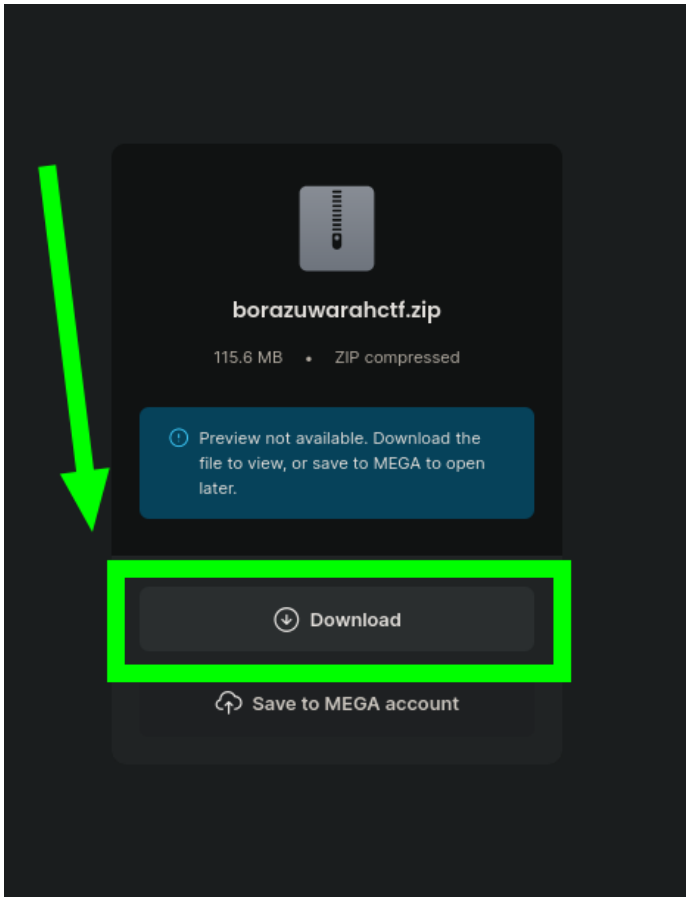
BorazuwarahCTF es una máquina vulnerable enfocada en practicar enumeración básica, análisis de metadatos, fuerza bruta y acceso inicial por SSH. Permite aplicar técnicas de reconocimiento y escalada de privilegios en un entorno controlado.

Vamos a buscar la máquina en la página https://dockerlabs.es/ y descargamos el laboratorio correspondiente para desplegarlo en Docker.



POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	**FACULTAD DE INGENIERIAS** **DIPLOMADO EN CIBERSEGURIDAD** **LABORATORIO KALI LINUX**	Código: FD-GC195 Versión: 01

ASIGNATURA	**CÓDIGO:** ING: Diplociber		**NOMBRE:** PRACTICA KALI_LINUX		
PROFESOR: Edwin Andrés Ochoa Agudelo				**FECHA:** 06/10/2026	
TIPO DEVALUACIÓN	**TALLER**	**QUIZ**	**PARCIAL**	**FINAL**	**¿OTRO – CUÁL?**
	N°3→10%				



ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX			
PROFESOR: Edwin Andrés Ochoa Agudelo				FECHA: 06/10/2026	
TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Para esta parte, extraemos el archivo comprimido .zip de la máquina y la desplegamos utilizando docker.

```
┌──(root㉿kali)-[/home/borazuwarahctf]
└─# unzip borazuwarahctf.zip
Archive:  borazuwarahctf.zip
  inflating: auto_deploy.sh
  inflating: borazuwarahctf.tar

┌──(root㉿kali)-[/home/borazuwarahctf]
└─# ls
auto_deploy.sh  borazuwarahctf.tar  borazuwarahctf.zip

┌──(root㉿kali)-[/home/borazuwarahctf]
└─#
```

```
┌──(root㉿kali)-[/home/borazuwarahctf]
└─# chmod +x auto_deploy.sh

┌──(root㉿kali)-[/home/borazuwarahctf]
└─# ./auto_deploy.sh borazuwarahctf.tar

                    ##        .
              ## ## ##       ==
           ## ## ## ##      ===
       /"""""""""""""""""\___/ ===
  ~~~ {~~ ~~~~ ~~~ ~~~~ ~~ ~ /  ===- ~~~
       \______ o          __/
         \    \        __/
          \____\______/

 _____ _____ _____ _____ _____ _____ _____ _____
|_____|_____|_____|_____|_____|_____|_____|_____|

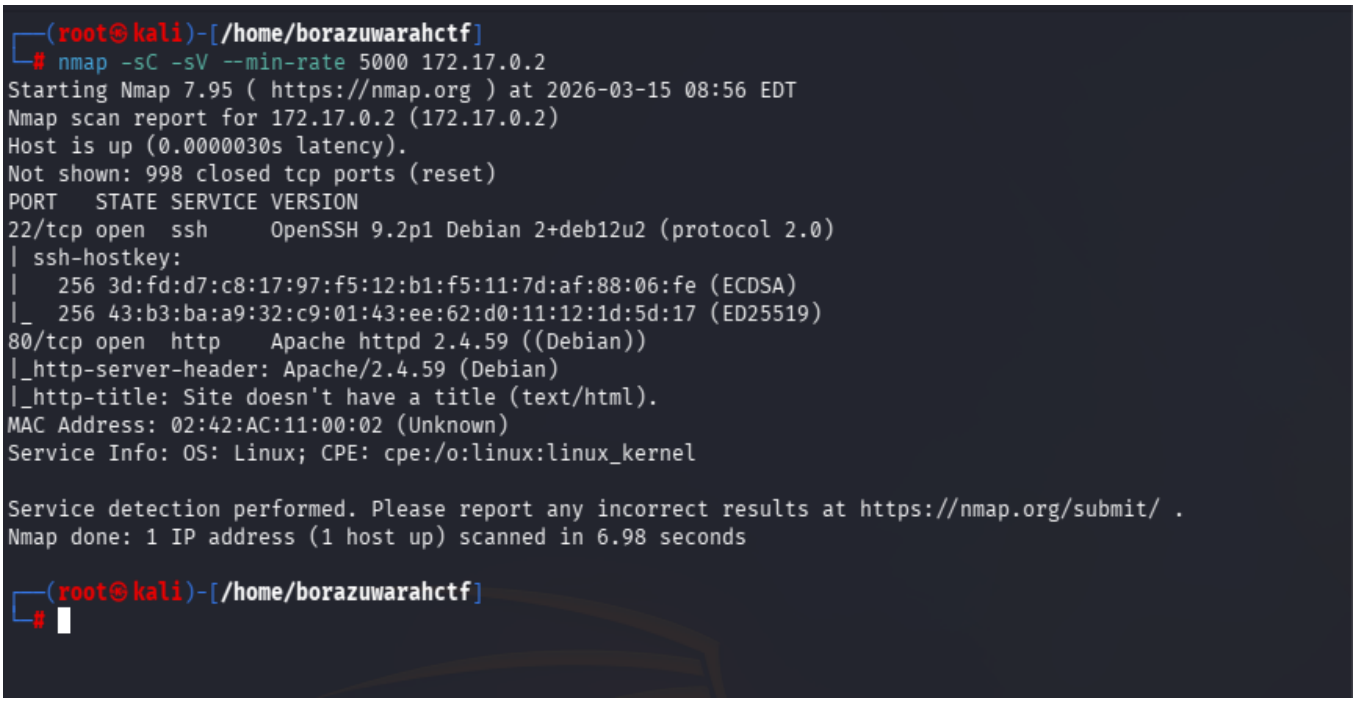
Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es ⟶ 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Ahora, se abrirá una nueva terminal para empezar a realizar el descubrimiento del sistema. Como conocemos la dirección IP de la máquina vulnerable (172.17.0.2), comenzaremos

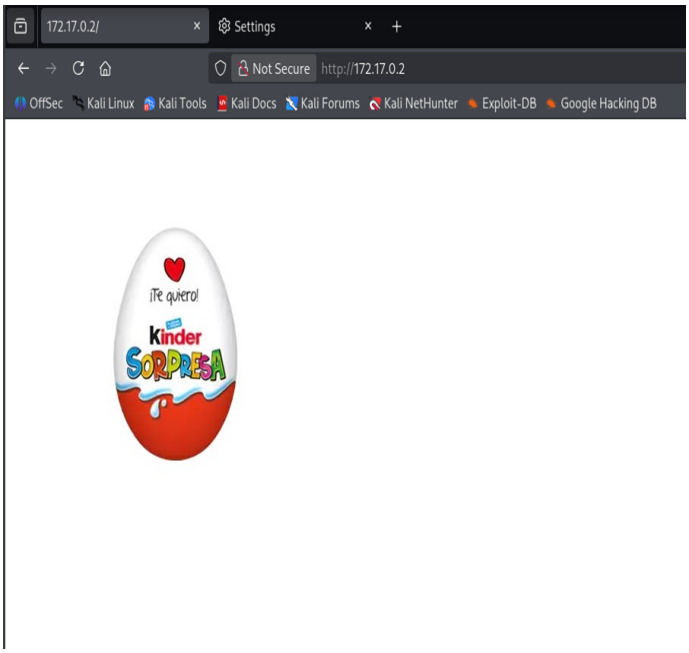
realizando un escaneo de red nmap. En esta ocasión, se usará el comando nmap -sC -sV --min-rate 5000 172.17.0.2



Se ha realizado un escaneo agresivo debido a que se está realizando en un entorno controlado y no es importante el ser detectado. Si se busca hacer el mínimo ruido posible será necesario utilizar el argumento **-sS** se usa para no ser detectado fácilmente, porque no completa la conexión TCP. Además, **no se usará –min-rate.**

Basados en la información encontrada, debemos dirigirnos a explorar los servicios encontrados.

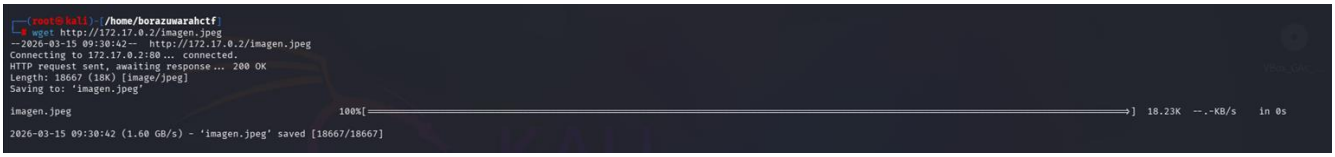
<table>
<tr><td rowspan="2">POLITÉCNICO COLOMBIANO
JAIME ISAZA CADAVID</td><td colspan="4">FACULTAD DE INGENIERIAS
DIPLOMADO EN CIBERSEGURIDAD
LABORATORIO KALI LINUX</td><td>Código:
FD-GC195</td></tr>
<tr><td>Versión: 01</td></tr>
<tr><td>ASIGNATURA</td><td colspan="2">CÓDIGO: ING: Diplociber</td><td colspan="2">NOMBRE: PRACTICA KALI_LINUX</td></tr>
<tr><td colspan="3">PROFESOR: Edwin Andrés Ochoa Agudelo</td><td colspan="3">FECHA: 06/10/2026</td></tr>
<tr><td rowspan="2">TIPO DEVALUACIÓN</td><td>TALLER</td><td>QUIZ</td><td>PARCIAL</td><td>FINAL</td><td>¿OTRO – CUÁL?</td></tr>
<tr><td>N°3→10%</td><td></td><td></td><td></td><td></td></tr>
</table>

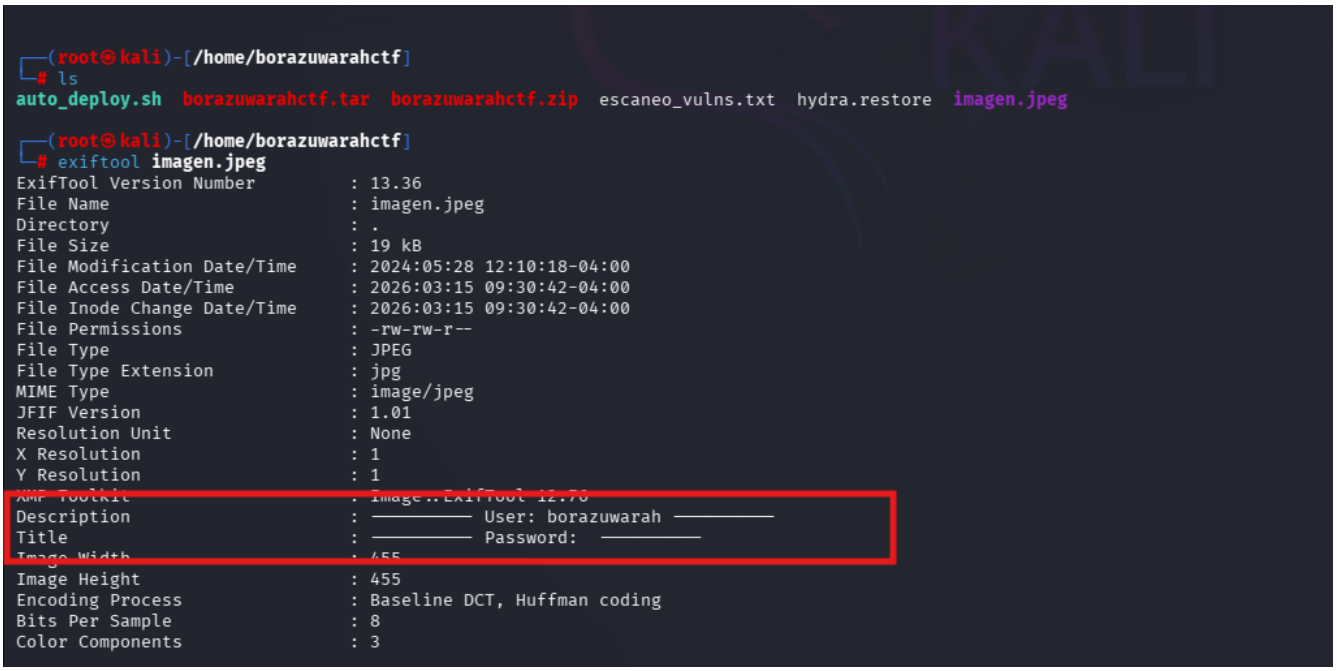


Tras analizar los servicios, no se encuentra una forma de acceso a través de ellos. Así que se dispondrá a descargar la imagen proporcionada por el servidor web http y analizar sus metadatos a través de **exiftool**.

Los metadatos son información oculta dentro de un archivo, como autor, fecha o programa usado. No eliminarlos es una mala práctica porque pueden revelar datos sensibles útiles para un atacante.

El comando wget permite descargar la imagen publicada por el servidor web. Ejemplo: wget http://172.17.0.2/imagen.jpeg





Si prestamos atención, hemos extraído la metadata de la imagen, utilizando específicamente una herramienta para ello, llamada exiftool; en la que, casualmente, están inscritos unos secretos, pero el de la contraseña está vacío. Para obtener la contraseña, solo basta realizar

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX			
PROFESOR: Edwin Andrés Ochoa Agudelo				FECHA: 06/10/2026	
TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

un ataque de fuerza bruta con hydra con el comando hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt.gz ssh://172.17.0.2 -t 64



Como podemos ver, en la ejecución anterior se han encontrado los secretos para acceder, vamos a intentarlo haciendo uso del protocolo SSH

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX			
PROFESOR: Edwin Andrés Ochoa Agudelo				FECHA: 06/10/2026	
TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

```
┌──(root㉿kali)-[/home/borazuwarahctf]
└─# ssh borazuwarah@172.17.0.2
borazuwarah@172.17.0.2's password:
Linux 5e6cb6a87bef 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
borazuwarah@5e6cb6a87bef:~$ id
uid=1000(borazuwarah) gid=1000(borazuwarah) groups=1000(borazuwarah),27(sudo)
borazuwarah@5e6cb6a87bef:~$
```

Una vez con acceso al usuario, se utiliza el comando sudo -l para ver los binarios con permisos sudo que tenga este usuario acceso.

En este caso se muestra que se puede ejecutar cualquier comando con sudo sin necesidad de contraseña (solo pedirá la de borazuwarah). Se ejecuta sudo su para acceder a root. Acá podemos investigar de la importancia del archivo sudoers

```
borazuwarah@5e6cb6a87bef:~$ sudo -l
Matching Defaults entries for borazuwarah on 5e6cb6a87bef:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User borazuwarah may run the following commands on 5e6cb6a87bef:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@5e6cb6a87bef:~$ sudo su
[sudo] password for borazuwarah:
root@5e6cb6a87bef:/home/borazuwarah#
```

POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	FACULTAD DE INGENIERIAS DIPLOMADO EN CIBERSEGURIDAD LABORATORIO KALI LINUX	Código: FD-GC195 Versión: 01

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Guía complementaria para el informe de laboratorio

Esta práctica integra dos laboratorios desarrollados en el diplomado. El objetivo no es entregar únicamente capturas de pantalla, sino demostrar comprensión técnica de cada comando ejecutado, interpretar los resultados y explicar qué riesgo o aprendizaje de ciberseguridad se evidencia en cada paso. Cada estudiante debe documentar la ejecución en Kali Linux con pantallazos claros, explicación propia y reflexión defensiva.

Regla ética obligatoria: todos los comandos deben ejecutarse únicamente en máquinas vulnerables del laboratorio, contenedores locales, CTF o entornos expresamente autorizados. No se permite probar estos comandos contra sitios web, servidores institucionales, redes empresariales o direcciones públicas sin autorización escrita.

Nombre del estudiante	
Diplomado	Ciberseguridad Informática y Resiliencia Digital
Sistema operativo atacante	Kali Linux
Entorno de práctica	Máquinas vulnerables desplegadas en laboratorio / Docker / red local controlada
Laboratorio 1	BorazuwarahCTF: enumeración, metadatos, fuerza bruta autorizada, acceso inicial y sudoers
Laboratorio 2	WordPress wp-cron.php: prueba controlada de disponibilidad y análisis de mitigación
Fecha de entrega	

1. Competencias a desarrollar

Aplicar comandos básicos y herramientas de Kali Linux para reconocimiento y análisis de servicios en un entorno controlado.

Interpretar salidas de terminal, identificar evidencias relevantes y diferenciar entre ejecución mecánica y análisis técnico.

Reconocer riesgos asociados a exposición de servicios, metadatos, contraseñas débiles, permisos sudo y abuso de recursos en aplicaciones web.

Proponer medidas de mitigación desde una perspectiva de ciberseguridad defensiva, legal y ética.

2. Producto final que debe entregar el estudiante

Un informe en Word o PDF con portada, introducción, desarrollo de los dos laboratorios, evidencias, análisis, conclusiones y recomendaciones de seguridad.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Pantallazos legibles de cada comando clave. Cada pantallazo debe incluir la terminal completa, el comando ejecutado y la salida obtenida.
Debajo de cada pantallazo debe aparecer una explicación de mínimo 5 líneas: qué hace el comando, qué resultado se obtuvo, qué significa y por qué es importante para la seguridad.
No se aceptan capturas sueltas sin explicación. La evidencia debe estar organizada por laboratorio, paso y objetivo técnico.
El estudiante debe ocultar o reemplazar datos sensibles si aparecen credenciales, rutas personales o información no necesaria para la evaluación.

3. Formato obligatorio para documentar cada comando

Después de cada fila, el estudiante debe insertar el pantallazo correspondiente con un título: Figura X. Evidencia del comando ejecutado.

Paso	Comando ejecutado	Propósito técnico	Resultado observado	Explicación del estudiante
1	Escriba aquí el comando	Explique el propósito	Describa la salida obtenida	Interprete el resultado y relaciónelo con el riesgo

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Laboratorio 1. BorazuwarahCTF: reconocimiento, metadatos, fuerza bruta autorizada y escalada básica

Contexto: BorazuwarahCTF es una máquina vulnerable orientada a practicar enumeración básica, análisis de metadatos, fuerza bruta autorizada y acceso inicial por SSH. En este laboratorio el estudiante debe reconstruir el proceso técnico desde el despliegue hasta la revisión de privilegios, explicando qué información aporta cada comando y qué mala práctica de seguridad se evidencia.

Importante: en una evaluación profesional no basta con decir “el comando encontró algo”. Debe explicarse qué encontró, cómo se interpreta y qué decisión técnica permite tomar.

1.1. Evidencias mínimas esperadas

Fase	Comando o acción	Pantallazo requerido	Qué debe explicar el estudiante	Riesgo o aprendizaje
Despliegue	Descomprimir la máquina y desplegarla con Docker	Terminal con despliegue correcto e IP asignada	Cómo se preparó el entorno y por qué se usa una máquina vulnerable controlada	Uso de laboratorios aislados
Conectividad	ping -c 4 172.17.0.2 / ip a / docker ps	Evidencia de IP y conectividad	Qué significa que el host responda y cómo se identifica el objetivo	Reconocimiento inicial
Enumeración	nmap -sC -sV --min-rate 5000 172.17.0.2	Salida de puertos y servicios	Explicar -sC, -sV, --min-rate y servicios detectados	Superficie de ataque

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Alternativa sigilosa	nmap -sS -sV 172.17.0.2	Comparación con escaneo agresivo	Diferencia entre velocidad, ruido y detección	OPSEC y monitoreo
Servicio web	curl -I http://172.17.0.2 / navegación web	Respuesta HTTP o página observada	Qué servicio responde y qué pistas entrega	Enumeración web
Descarga de archivo	wget http://172.17.0.2/imagen.jpeg	Archivo descargado	Qué hace wget y por qué se descarga la evidencia	Exposición de archivos
Metadatos	exiftool imagen.jpeg	Metadatos visibles	Qué son metadatos y qué información sensible pueden revelar	Fuga de información
Fuerza bruta autorizada	hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt.gz ssh://172.17.0.2 -t 64	Resultado de credenciales encontradas	Explicar usuario, diccionario, protocolo SSH y parámetro -t	Contraseñas débiles
Acceso SSH	ssh borazuwarah@172.17.0.2	Inicio de sesión exitoso	Qué implica obtener acceso inicial y	Acceso no autorizado si fuera real

			cómo se valida el usuario	
Post-explotación básica	whoami, id, hostname, pwd, ls -la	Identificación del contexto	Qué información entrega cada comando	Reconocimiento interno
Privilegios	sudo -l	Permisos sudo disponibles	Qué permite revisar sudo -l y por qué es crítico	Mala configuración sudoers
Escalada controlada	sudo su / whoami	Cambio a root si aplica	Qué significa root y por qué representa control total del sistema	Principio de mínimo privilegio

1.2. Guía de explicación de comandos del laboratorio 1

nmap -sC -sV --min-rate 5000 172.17.0.2

Realiza reconocimiento de puertos y servicios. -sC ejecuta scripts comunes de NSE, -sV intenta identificar versiones de servicios y --min-rate acelera el envío de paquetes. En laboratorio permite obtener información rápida, pero en redes reales puede generar alertas.

wget http://172.17.0.2/imagen.jpeg

Descarga un archivo desde el servidor web para analizarlo localmente. Sirve para recolectar evidencia y revisar si el recurso expone información sensible.

exiftool imagen.jpeg

Extrae metadatos de un archivo, como autor, fechas, software usado o comentarios. En seguridad permite evidenciar fuga de información por archivos mal publicados.

hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt.gz ssh://172.17.0.2 -t 64

Ejecuta una prueba de fuerza bruta autorizada contra SSH usando un usuario conocido y un diccionario. Debe explicarse como riesgo de contraseñas débiles, no como técnica para atacar sistemas reales.

ssh borazuwarah@172.17.0.2

Abre una sesión remota por SSH con las credenciales obtenidas en el laboratorio. Permite validar el acceso inicial.

sudo -l

Lista qué comandos puede ejecutar el usuario con privilegios elevados. Es clave para detectar configuraciones peligrosas en sudoers.

sudo su

Cambia a usuario root cuando la política sudo lo permite. En el informe se debe explicar por qué este permiso debe restringirse.

1.3. Preguntas de análisis del laboratorio 1

¿Qué diferencia hay entre conocer que un puerto está abierto y conocer la versión exacta del servicio que escucha en ese puerto?
¿Por qué los metadatos de una imagen pueden convertirse en una fuente de inteligencia para un atacante?
¿Qué controles podrían evitar que una contraseña débil permita acceso por SSH?
¿Qué significa el principio de mínimo privilegio y cómo se relaciona con sudo -l y sudoers?
Si esta máquina fuera un servidor empresarial real, ¿qué tres acciones de mitigación recomendaría primero y por qué?

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Laboratorio 2. WordPress y wp-cron.php: prueba controlada de disponibilidad

Contexto: WordPress utiliza wp-cron.php para ejecutar tareas programadas cuando recibe visitas. El laboratorio muestra cómo una ejecución pública y repetida de ese archivo puede generar consumo excesivo de CPU y memoria en una máquina vulnerable de práctica. El enfoque de este informe debe ser comprender el fenómeno, registrar evidencias y proponer mitigaciones defensivas.

Esta sección se debe redactar como prueba de carga y análisis de resiliencia en laboratorio. No se debe presentar como una guía para afectar servicios reales. Todo resultado debe incluir recomendación de mitigación.

2.1. Evidencias mínimas esperadas

Fase	Comando o acción	Pantallazo requerido	Qué debe explicar el estudiante	Riesgo o aprendizaje
Despliegue	sudo bash auto_deploy.sh cronkill.tar	Máquina desplegada e IP asignada	Qué hace el script de despliegue y qué recursos limita el contenedor	Aislamiento del laboratorio
Verificación web	Abrir http://172.17.0.2	Página WordPress visible	Cómo se confirma que el servicio está disponible antes de la prueba	Línea base de disponibilidad
Exposición wp-cron	Abrir http://172.17.0.2/wp-cron.php	Respuesta del endpoint	Por qué wp-cron.php es accesible y qué función cumple	Exposición pública de procesos internos
Monitoreo previo	top / htop / docker stats	CPU y memoria antes de la prueba	Por qué se registra una línea base de recursos	Medición antes/después

Prueba controlada	ab -n 5000 -c 50 -k -H "Accept-Encoding: gzip, deflate" http://172.17.0.2/wp-cron.php	Salida de ApacheBench	Explicar -n, -c, -k, -H, tiempos, errores y solicitudes por segundo	Agotamiento de recursos
Monitoreo durante	docker stats / top	CPU o memoria durante la prueba	Relacionar concurrencia con consumo de recursos	Impacto operacional
Efecto visible	Abrir nuevamente el sitio en navegador	Página lenta, bloqueada o sin respuesta	Cómo se evidencia la afectación de disponibilidad	Denegación de servicio en laboratorio
Recuperación	Finalizar prueba / reiniciar contenedor si el docente lo indica	Servicio recuperado	Qué acciones permitieron recuperar disponibilidad	Resiliencia y continuidad
Mitigación	Explicar controles: cron real, rate limiting, WAF, monitoreo, caché	Tabla o párrafo de recomendaciones	Cómo se reduce el riesgo sin afectar tareas legítimas	Defensa y hardening

2.2. Guía de explicación de comandos del laboratorio 2

sudo bash auto_deploy.sh cronkill.tar

Ejecuta el script de despliegue de la máquina vulnerable cronkill. Debe documentarse la IP asignada y los límites de recursos del contenedor.

curl -I http://172.17.0.2

Consulta encabezados HTTP para verificar que el servicio responde sin descargar todo el contenido.

curl -I http://172.17.0.2/wp-cron.php

Permite comprobar si el archivo wp-cron.php está expuesto. Si responde públicamente, se debe analizar el riesgo de ejecución repetida.

docker stats

Muestra consumo de CPU, memoria y red de los contenedores. Sirve para comparar antes, durante y después de la prueba.

ab -n 5000 -c 50 -k -H "Accept-Encoding: gzip, deflate" http://172.17.0.2/wp-cron.php

ApacheBench realiza solicitudes HTTP controladas al endpoint del laboratorio. -n define el total de solicitudes, -c la concurrencia, -k mantiene conexiones abiertas y -H agrega una cabecera HTTP. El estudiante debe interpretar si hubo fallos, lentitud o saturación.

Para equipos con pocos recursos, el docente puede reducir la carga, por ejemplo: ab -n 300 -c 10 http://172.17.0.2/wp-cron.php. La finalidad pedagógica es observar la relación entre concurrencia, recursos y disponibilidad, no maximizar el daño.

2.3. Medidas de mitigación que debe analizar el estudiante

Control defensivo	Qué busca prevenir	Cómo se explicaría en el informe
Deshabilitar pseudo-cron público y usar cron real del servidor	Evitar que cada visita dispare tareas costosas de WordPress	Explicar que las tareas programadas se ejecutan por horario controlado, no por cada solicitud pública.
Rate limiting en servidor web, proxy o WAF	Reducir peticiones repetitivas desde una misma fuente o patrón	Relacionar con límites de solicitudes por IP, por ruta y por intervalo de tiempo.
Bloqueo o restricción de acceso a wp-cron.php cuando aplique	Disminuir exposición directa del endpoint	Aclarar que debe validarse para no romper tareas legítimas del sitio.
Monitoreo de logs, CPU, RAM y errores HTTP	Detectar saturación temprana y responder antes de una caída	Incluir indicadores: 5xx, latencia, CPU alta, memoria alta, conexiones simultáneas.
Caché, CDN y endurecimiento de WordPress	Reducir carga dinámica y mejorar disponibilidad	Explicar que no reemplaza la corrección de configuración, pero ayuda a resiliencia.

2.4. Preguntas de análisis del laboratorio 2

¿Por qué wp-cron.php no se considera necesariamente un bug, sino un problema de diseño o configuración cuando queda expuesto a ejecución repetida?
¿Qué diferencia hay entre disponibilidad, confidencialidad e integridad en este laboratorio?
¿Qué evidencia permite afirmar que el servicio se saturó: salida de ab, navegador, CPU/RAM o logs? Justifique.
¿Por qué una prueba de carga autorizada puede ser útil para mejorar la resiliencia digital de una organización?
Proponga tres controles concretos para reducir el riesgo observado y explique cuál implementaría primero.

POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	FACULTAD DE INGENIERIAS DIPLOMADO EN CIBERSEGURIDAD LABORATORIO KALI LINUX	Código: FD-GC195 Versión: 01

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Estructura sugerida del informe final

Sección	Contenido esperado	Extensión sugerida	Criterio de calidad
Portada	Nombre, diplomado, docente, fecha, título de la práctica	1 página	Datos completos y presentación institucional
Introducción	Propósito de los laboratorios y alcance ético	1/2 página	Claridad y enfoque defensivo
Objetivos	Objetivo general y 3 específicos	1/2 página	Relacionados con reconocimiento, análisis y mitigación
Laboratorio 1	Evidencias, comandos, explicación, resultados y análisis	4-6 páginas	Pantallazos legibles con interpretación propia
Laboratorio 2	Evidencias, monitoreo, prueba controlada, efecto y mitigación	4-6 páginas	Relación entre recursos, disponibilidad y controles
Conclusiones	Aprendizajes técnicos, éticos y defensivos	1 página	No repetir pasos; sintetizar hallazgos
Recomendaciones	Acciones de hardening y buenas prácticas	1 página	Concretas y aplicables a empresa o institución
Anexos	Capturas adicionales, logs o tablas de comandos	Opcional	Ordenados y referenciados

POLITÉCNICO COLOMBIANO JAIME ISAZA CADAVID	FACULTAD DE INGENIERIAS DIPLOMADO EN CIBERSEGURIDAD LABORATORIO KALI LINUX	Código: FD-GC195 Versión: 01

ASIGNATURA	**CÓDIGO:** ING: Diplociber	**NOMBRE:** PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		**FECHA:** 06/10/2026

TIPO DEVALUACIÓN	**TALLER**	**QUIZ**	**PARCIAL**	**FINAL**	**¿OTRO – CUÁL?**
	N°3→10%				

Rúbrica de evaluación sugerida

Criterio	Superior	Alto	Básico	Puntaje
Ejecución técnica de los laboratorios	Ejecuta todos los pasos, evidencia resultados y corrige errores menores de forma autónoma.	Ejecuta la mayoría de pasos con evidencias claras.	Presenta pasos incompletos o capturas sin suficiente orden.	25
Explicación de comandos	Explica propósito, parámetros, salida e interpretación de cada comando con lenguaje técnico.	Explica la mayoría de comandos y resultados.	Describe comandos de forma superficial o memorística.	25
Análisis de riesgos y mitigación	Relaciona hallazgos con riesgos reales y propone controles pertinentes.	Identifica riesgos y propone algunas medidas.	Menciona riesgos generales sin suficiente justificación.	20
Ética, legalidad y alcance del laboratorio	Diferencia claramente laboratorio autorizado de uso no permitido en sistemas reales.	Incluye advertencia ética básica.	No delimita adecuadamente el alcance de la práctica.	10
Presentación del informe	Documento organizado, legible, con títulos, figuras, tablas y	Documento ordenado con algunos	Documento desordenado o con evidencias poco legibles.	20

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

	conclusiones sólidas.	aspectos por mejorar.		

Lista de chequeo antes de entregar

☐ Incluí portada y datos completos.

☐ Separé claramente el laboratorio 1 y el laboratorio 2.

☐ Cada comando tiene pantallazo, explicación y análisis.

☐ Expliqué los parámetros principales de nmap, hydra, ssh, sudo, ab y docker stats.

☐ No incluí información sensible innecesaria ni credenciales reales externas al laboratorio.

☐ Relacioné cada hallazgo con un riesgo de seguridad.

☐ Propuse medidas de mitigación para ambos laboratorios.

☐ Mis conclusiones explican lo aprendido y no solo repiten el procedimiento.

ASIGNATURA	CÓDIGO: ING: Diplociber	NOMBRE: PRACTICA KALI_LINUX
PROFESOR: Edwin Andrés Ochoa Agudelo		FECHA: 06/10/2026

TIPO DEVALUACIÓN	TALLER	QUIZ	PARCIAL	FINAL	¿OTRO – CUÁL?
	N°3→10%				

Anexo. Mini glosario de comandos usados en la práctica

Comando	Uso en la práctica	Explicación breve
nmap	Reconocimiento de puertos y servicios	Permite identificar servicios expuestos y versiones aproximadas.
curl	Verificación HTTP	Consulta respuestas web desde terminal; útil para encabezados y pruebas rápidas.
wget	Descarga de archivos	Recupera archivos por HTTP/HTTPS/FTP para analizarlos localmente.
exiftool	Análisis de metadatos	Extrae información oculta o embebida en archivos.
hydra	Prueba de credenciales autorizada	Automatiza intentos de autenticación con diccionarios en entornos permitidos.
ssh	Acceso remoto seguro	Permite iniciar sesión en un sistema remoto mediante credenciales.
sudo -l	Revisión de privilegios	Lista comandos que un usuario puede ejecutar con permisos elevados.
sudo su	Cambio a root cuando está permitido	Permite asumir privilegios administrativos; debe restringirse.
docker stats	Monitoreo de contenedores	Muestra CPU, memoria, red y E/S de contenedores en tiempo real.
ab	Prueba de carga HTTP controlada	Envía solicitudes HTTP para medir rendimiento y

		comportamiento ante concurrencia.
top / htop	Monitoreo del sistema	Permite observar procesos, CPU, memoria y carga del sistema.